

DECISION

Subject: Complaint regarding the disclosure of personal data

I refer to the complaint submitted to my Office regarding the above subject by XXX (hereinafter referred to as the "Complainant") against GoGordian Real Estate, which operates under Gordian Servicing Limited (hereinafter referred to as the "Respondent"). After examining the complaint, based on the powers conferred upon me by Articles 57 and 58 of the General Data Protection Regulation, (EU) 2016/679 (hereinafter referred to as the "Regulation"), I present the following:

2. Facts/Positions of the Parties

2.1. The complaint submitted to me on 14/06/2023 concerns the disclosure of the Complainant's personal data to a third party. Specifically, the Complainant informed me that an unknown person visited his residence regarding a specific piece of land. According to this person, the Respondent informed him that he is a co-owner with the Complainant of the said property and provided him with information regarding the name and residence address of the Complainant. The Complainant's position is that this information, particularly his residence address, should not have been given to someone he does not know and without his knowledge.

2.2. In order to proceed with the investigation of the complaint, on 16/06/2023, I sent an email to the Complainant requesting that he provide me with details of the property in question and/or details of the unknown person. The Complainant provided me with the required information on 09/07/2023.

On 17/07/2023, the positions of the Respondent regarding the matter were requested, which responded on 04/08/2023, stating among other things, the following:

2.3.1. The Respondent was, and is, a licensed credit management company at the relevant time and, by virtue of a related service provision and credit management agreement with Gordian Holdings Limited, manages the portfolio of the latter, which is licensed as a Credit Acquisition Company. In the context of providing services to Gordian Holdings Limited, the Respondent processes data, which is governed by a relevant Data Processing Agreement between the two companies.

2.3.2. The Respondent identified a property with a registration number similar to one of the registration numbers of the parcels provided by the Complainant, in which Gordian Holdings Limited is a co-owner with the Complainant.

2.3.3. Due to the aforementioned relationship, the collection and processing of the Complainant's personal data was carried out on the basis of legitimate interest. The Complainant's personal data was obtained from the land registry inquiry form of the property in question, which is issued from the land registry database.

2.3.4. The involved third party had expressed interest in purchasing the share held by Gordian Holdings Limited and requested a copy of the title deed. The Officer who was responsible for handling the promotion of the specific property inadvertently did not proceed to delete the personal details (name and residence address) of the co-owner, resulting in the third party having access to the Complainant's personal data.

2.3.5. The Respondent has drawn the attention of the staff involved in property promotion to be particularly careful regarding the disclosure of confidential information and especially personal data. Staff are instructed to delete personal data from documents provided to interested buyers.

2.3.6. In cases where interested buyers wish to contact co-owners to discuss any matters concerning the properties for sale, the Respondent's staff communicates with its co-owners and informs them about the interested buyers' desire to communicate. Communication between the two parties can only be arranged after obtaining the consent of the co-owners.

2.3.7. In compliance with the Regulation and national legislation N.125(I)/2018, the Respondent has established an effective framework for the management and protection of personal data, which

includes:

- i. Establishment of policies and procedures governing the protection of personal data.
- ii. Maintenance of a record of processing activities of personal data.
- iii. Implementation of a strict protocol for information security.
- iv. Inclusion of terms regarding compliance with the European regulation and national legislation in contracts for outsourcing tasks to third parties.
- v. Provision of training to all staff on issues related to information security and the protection of personal data.
- vi. Regular assessment of the effectiveness of existing control mechanisms and taking corrective measures where deemed necessary.

2.3.8. The Respondent concluded that in this particular case, the disclosure of the Complainant's personal data to a third party was the result of the improper application of existing instructions to the staff, and it cannot be inferred that there are weaknesses in the control mechanisms for the protection of personal data, as this constitutes an isolated incident.

2.3.9. For the purpose of reducing the likelihood of repeating the same mistake, the Responsible Party has issued a strict written directive to all its staff, which refers to the specific incident and once again calls on the staff to be particularly careful in the management of personal data and especially in the transmission of documents to third parties.

2.3.10. The Responsible Party would communicate with the Whistleblower to apologize for the incident.

3. Legal Framework

3.1. Based on Recital 74 of the Preamble of the Regulation, "There should be established liability and compensation obligations for the data controller for any processing of personal data carried out by the data controller or on behalf of the data controller. In particular, the data controller should be obliged to implement appropriate and effective measures and to be able to demonstrate compliance of processing activities with this Regulation, including the effectiveness of the measures. Such measures should take into account the nature, context, scope, and purposes of the processing and the risks to the rights and freedoms of natural persons.

3.2. Furthermore, pursuant to Recital 83 of the Preamble of the Regulation, "To maintain security and avoid processing in violation of this Regulation, the data controller or the processor should assess the risks posed by the processing and implement measures to mitigate those risks, such as through encryption. Such measures should ensure an appropriate level of security, which includes confidentiality, taking into account the latest developments and the cost of implementation in relation to the risks and the nature of the personal data that needs to be protected. In assessing the risk to the security of the data, attention should be paid to the risks arising from the processing of personal data, such as accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that has been transmitted, stored, or otherwise processed, which could lead to physical, material, or non-material damage."

3.3. Based on Article 4 of the Regulation,

"1) 'personal data': any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that natural person,

2) 'processing': any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure, or destruction,

7) 'data controller': the natural or legal person, public authority, agency, or other body which, alone or

jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the data controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

In paragraph 19 of the Guidelines 07/2020 on the concepts of the data controller and the processor under the GDPR, it is noted that: "In principle, any processing of personal data carried out by employees in the context of the activities of an organization can be considered to be carried out under the control of that organization. In exceptional circumstances, however, an employee may decide to use personal data for their own purposes and, as a result, unlawfully exceed the powers granted to them (e.g., to establish their own company or for a similar purpose). Consequently, as the data controller, the organization has a duty to ensure that appropriate technical and organizational measures are implemented, including training and informing employees, which will ensure compliance with the GDPR."

3.5.

Article 5 of the Regulation includes the principles governing the processing of personal data. The principle of integrity and confidentiality, as referred to in paragraph 1(f) of this article, stipulates that personal data "shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures."

In Article 24 of the Regulation, the following is provided: "Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation. The aforementioned measures shall be reviewed and updated when necessary."

3.6.

Additionally, for the security of processing, Article 32 of the Regulation provides that: "1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, as appropriate: a) the pseudonymization and encryption of personal data, b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures for ensuring the security of processing.

2. In assessing the appropriate level of security, account shall be taken in particular of the risks that arise from the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed.

3. Adherence to an approved code of conduct as referred to in Article 40 or an approved certification mechanism as referred to in Article 42 may be used as an element to demonstrate compliance with the requirements of paragraph 1 of this Article.

4. The data controller and the processor shall take measures to ensure that any natural person acting under the authority of the data controller or the processor who has access to personal data processes them only on instructions from the data controller, unless he or she is required to do so by Union or Member State law."

3.7.

Regarding individuals acting under the authority of the data controller or the processor, paragraph 88 of Guidelines 07/2020 is relevant: "While the terms 'personal data', 'data subject', 'data controller', and 'processor' are defined in the Regulation, the concept of 'persons who, under the direct authority of the data controller or the processor, are authorized to process personal data' is not defined. However, it is

generally understood as referring to individuals who belong to the legal entity of the data controller or the processor (employees or roles largely comparable to employment, e.g., temporary staff provided through a temporary employment agency), but only to the extent that they are granted authorized access to personal data. An employee, etc., who gains access to data for which he or she does not have authorized access and for purposes other than those of the employer does not fall into this category. Conversely, the employee in question should be considered a third party in relation to the processing carried out by the employer. To the extent that the employee processes personal data for his or her own purposes or for purposes different from those of his or her employer, he or she will be considered a data controller and will bear all legal consequences and responsibilities associated with the processing of personal data."

3.8.

Pursuant to Article 58(2), the Data Protection Commissioner has all of the following corrective powers:

a) to issue warnings to the data controller or the processor that intended processing operations are likely to infringe provisions of this Regulation,

b) to issue reprimands to the data controller or the processor when processing operations have infringed provisions of this Regulation,

5

γ) to instruct the data controller or the processor to comply with the requests of the data subject for the exercise of their rights under this regulation,

δ) to instruct the data controller or the processor to ensure that processing operations are in compliance with the provisions of this regulation, if necessary, in a specific manner and within a specified timeframe,

ε) to instruct the data controller to notify the data subject of a personal data breach,

σ) to impose a temporary or permanent restriction, including a prohibition on processing,

ζ) to issue an instruction for the correction or deletion of personal data or restriction of processing pursuant to Articles 16, 17, and 18 and to instruct the communication of these actions to recipients to whom the personal data have been disclosed pursuant to Article 17 paragraph 2 and Article 19,

η) to withdraw the certification or to order the certification body to withdraw a certificate issued under Articles 42 and 43 or to order the certification body not to issue a certification, provided that the certification requirements are not met or are no longer met,

θ) to impose an administrative fine pursuant to Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the circumstances of each individual case,

ι) to instruct the suspension of the transfer of data to a recipient in a third country or to an international organization.

3.10. Based on Article 51A of the Immovable Property (Tenure, Registration and Valuation) Law (Cap. 224), "(1) The Director (of the Department of Land and Surveys) shall provide any interested person, upon payment of the prescribed fee, with any information relating to any entry in any register or other book maintained in any District Land Office. (2) For the purposes of subsection (1), 'interested person' means the owner, their universal and special successors, the owner of any trees, buildings, or other objects on land belonging to another person and vice versa, the beneficiary of any right or interest in the immovable property, the person who satisfies the Director that they are a prospective buyer or mortgagee, the plaintiff in any action against the owner of that property, the professional appraiser who would like certain information for the purposes of appraising a specific immovable property for a case related to compulsory acquisition, as well as a lawyer to whom it has been proven that any of the aforementioned persons has entrusted to request any information regarding any entry pursuant to subsection (1) and includes any person not specified in this manner to whom the Director wishes to specifically order the provision of any information.

4. Reasoning

4.1. According to Article 4 of the Regulation, the collection, retention, and disclosure of the complainant's details to a third party constitute processing of personal data. The complainant, as the natural person to whom these details pertain, constitutes the data subject. The entity against which the

complaint is made, determining the purpose and means of processing the data, constitutes the data controller.

According to the information I received from the entity against which the complaint is made, the Operator, due to an oversight and despite the instructions they had for the deletion of personal data from documents made available to third parties, did not proceed with the deletion of the complainant's personal details, resulting in the complainant's name and address coming into the possession of a third party.

4.3. The Operator of the entity against which the complaint is made, although acting outside the framework of the latter's instructions and orders, cannot be considered a separate data controller, because, according to the assumption of the entity against which the complaint is made, this action constitutes an isolated incident that occurred due to oversight, due to improper application of the relevant instructions. The Operator, in no case, exceeded their authority by setting other purposes and means of processing, different from those of their employer.

4.4. According to Article 5(1)(f), the entity against which the complaint is made, as the data controller, is obliged to ensure, using appropriate technical and organizational measures, that the processing it carries out guarantees the adequate security of personal data against unauthorized or unlawful processing. Based on Recital 74 and Article 24 of the Regulation, every data controller

****Processing****, is obliged to implement appropriate measures in order to ensure and demonstrate compliance with the Regulation, including the effectiveness of the measures. Furthermore, based on Recital 83 and Article 32, each data controller, through the implementation of appropriate measures, must ensure an adequate level of security against the risks posed by any form of processing and must ensure that any natural person acting under their authority processes personal data only in accordance with their instructions.

4.5. As I have been informed by the Respondent, it appears that they have taken security measures, establishing, among other things, policies and specific procedures that their staff must follow in order to ensure the protection of the personal data of the data subjects. Furthermore, they have provided training to all their staff regarding information security and data protection issues. Nevertheless, even though the complaint under examination concerns a single incident, it appears that the Respondent did not sufficiently ensure the effectiveness of the aforementioned measures and consequently the appropriate level of security against the risks arising from the processing, thereby violating the provisions of Articles 24 and 32 of the Regulation. The accidental disclosure of the name and address of the Complainant also constitutes a violation of Article 5(1)(f), in the sense that, as a result, the actions and/or omissions of a person under the direct supervision of the data controller, namely their employee, made the personal data of the Complainant accessible to a third party.

4.6. I appreciate the action taken by the Respondent regarding the complaint, such as informing the staff about the incident under examination and drawing their attention to be particularly careful in similar cases of document disposal to third parties. For the enhancement of the level of security against the risks posed by the specific processing, I believe that the Respondent should consider taking additional measures that would prevent similar errors (e.g., introducing the principle of dual control (four eyes principle)).

4.7. For the purposes of a comprehensive assessment of the incident under investigation, I take into account that the accidental disclosure of the details resulted in an intrusion into the private and family life of the Complainant, as the third party who was granted access proceeded to visit the residence of the Complainant.

4.8. Despite the above, it is noted that according to Article 51A(1) of the Immovable Property (Tenure, Registration and Valuation) Law (CAP. 224), the Director of the Department of Land and Surveys provides any interested person, upon payment of the prescribed fee, with any information regarding any entry in any register or other book maintained in any District Land Office. According to paragraph (2) of the same Article, the term "interested person" includes, among others, a person who satisfies the Director that they are a prospective buyer. This means that the person who accidentally received the

Complainant's details due to oversight by the Respondent's Officer could request access to those details through the process defined by the Land Registry and therefore their request could be evaluated by the Director of the Land Registry and possibly granted. However, this possibility does not justify the provision of access to such data by the Respondent, nor does it excuse their failure to prevent and deter the erroneous action of their Officer.

5. Conclusion

5.1. Taking into account all the above elements, as they have been presented, and based on the powers conferred upon me by Article 57(1)(f) of the Regulation, I find that there has been a violation by the Respondent of Articles 5(1)(f), 24(1), and 32 of the Regulation.

5.2. In light of the above, as well as the evidence before me, I take into account the following mitigating (1)-(8) and aggravating (9)-(10) factors:

- 1) the establishment of a framework for the management and protection of personal data by the Respondent and the implementation of corrective security measures to comply with the Regulation,
 - 2) a data subject whose data was disclosed to only one person,
 - 3) the complaint,
 - 4) similar to that of the complaint under examination,
 - 5) incident to the staff,
 - 6)
 - 7) the intention of the Respondent to apologize to the Complainant, the full cooperation of the Respondent with my Office, the fact that the complaint concerns a single incident that only affected the absence of intent and/or malice on the part of their Officer, the issuance of written guidance by the Respondent in which it is stated that there is no other complaint against the Respondent regarding the incident.
- the possibility of access to the complainant's data by the interested buyer through the procedure defined by the Property (Possession, Registration and Valuation) Law,
- 8) complaint,
 - 9) of his personal data by the Respondent to a third party.
- the fact that my Office became aware of the incident through the submission of the disturbance of the complainant's privacy, as a result of the notification

After considering:

the applicable legislative framework,

all the circumstances and factors that the complainant and the Respondent presented

5.3.

(a)

(b)

before me,

(c) the aforementioned mitigating and aggravating factors,

I find that, under the circumstances, the imposition of an administrative fine is not justified.

Nevertheless, exercising the powers conferred upon me by Article 58(2)(b) of the Regulation, I have decided to issue to the Respondent a Warning for the violation of Articles 5(1)(f), 24(1), and 32 of Regulation (EU) 2016/679.

5.4.

considered as an aggravating factor

In the event of a recurrence of a similar complaint, the present case will be taken into account

Eirini Loizidou Nicolaidou

Commissioner for the Protection of Personal Data

Nicosia, September 11, 2023